



MAAZ Zero Trust Assessment v4.1.0

コンセプトガイド

クロスマッピングの意義とフレームワーク間の関係性

CISA ZTMM v2 × MITRE ATT&CK × MITRE ATLAS × NIST AI RMF 1.0
+ OWASP LLM Top 10 2025 | EU AI Act 2024 | NIST GAI Profile (AI-600-1)

Version 4.1.0 | 2026

目次

- 1. 本ドキュメントの目的
- 2. ワークフロー
- 3. 課題認識：なぜクロスマッピングが必要か
- 4. フレームワーク間の関係性
- 5. クロスマッピングのメカニズム
- 6. ゼロトラスト実装のロードマップ
- 7. AI 時代のゼロトラスト拡張
- 8. 本ツールの設計思想
- 9. v4.1.0 新機能一覧
- 10. 今後の展望

1. 本ドキュメントの目的

本書は、MAAZ Zero Trust Assessment v4.1.O（以下「本ツール」）の設計思想とクロスマッピングの概念を解説するドキュメントである。操作手順ではなく、「なぜこのツールがこのように設計されているのか」を理解することを目的とする。

本書の位置付け

本書は操作マニュアルではありません。本ツールが採用するクロスマッピング手法の意義、フレームワーク間の関係性、およびゼロトラスト実装駆動型アセスメントの考え方を解説します。

本ツールが対象とするフレームワークと規格は以下の通りである。

フレームワーク	役割	本ツールでの位置付け
CISA ZTMM v2	ゼロトラスト成熟度モデル	実装軸 — 「どう実装するか」
MITRE ATT&CK	サイバー攻撃手法のナレッジベース (50 技法)	脅威軸 — 「何を防ぐか」 (従来型)
MITRE ATLAS	AI/ML 攻撃手法のナレッジベース (13 技法)	脅威軸 — 「何を防ぐか」 (AI 特有)
NIST AI RMF 1.0	AI リスク管理フレームワーク	管理軸 — 「何を管理すべきか」
OWASP LLM Top 10	LLM アプリの脆弱性ランキング	参照 — ATLAS 技法への補助マッピング
EU AI Act 2024	EU AI 規制	参照 — ガバナンス Lv4 の準拠基準

2. ワークフロー — 本ツールの使い方

本ツールは「コアフロー」3ステップと「詳細・検証」タブの2層構造で設計されている。初回アセスメントではコアフローの3ステップだけで完結し、詳細・検証はPDCAの「Check」フェーズで活用する。

2.1 コアフロー（3ステップ）

コアフローの流れ

Step 1: ZT ダッシュボード — AS-IS/TO-BE 設定 ⇒ Step 2: 脅威×ZT マッピング — 未対応箇所の把握 & TO-BE 調整 ⇒ Step 3: アクション計画 — ロードマップ策定

Step 1: ZT ダッシュボード — AS-IS/TO-BE 設定

各 ZTMM ピラー（6 個）のコントロール（18 個）について、現状の成熟度レベル（AS-IS: Lv1～Lv4）と目標レベル（TO-BE）を設定する。業種プリセット（金融・医療・製造・IT・政府・中小企業の 6 パターン）を適用すれば、TO-BE レベルを一括設定できる。

- 出力: AS-IS と TO-BE の差があるピラーが「ギャップ」として可視化される

Step 2: 脅威×ZT マッピング — 未対応箇所の把握 & TO-BE 調整

罫 63 の脅威技法（ATT&CK 50 + ATLAS 13）が ZTMM のどのコントロールで緩和されるかをマトリクス表示で確認する。脅威アクタープロファイル（APT29/APT28/Lazarus/APT10/Generic AI Actor）によるフィルタリングも可能。

Step 3: アクション計画 — ロードマップ策定

AS-IS/TO-BE ギャップから自動生成されたアクションカードを参照し、実装ロードマップを策定する。コントロール依存関係も考慮され、前提条件未達のコントロールには警告が表示される。

- エクスポート: CSV 出力・JSON 出力（Decision 連携用）・JSON インポートに対応

2.2 詳細・検証タブ

脅威評価（検証） — 理論値 vs 実測値の照合

ZTMM レベルベースの自動カバレッジ判定は「理論値」である。このタブでは、各脅威技法の防御実態を手動で評価（Full/Partial/Minimal/None）し、理論と実態の乖離を検出する。サブテクニック展開機能で下位手法も個別確認可能。

ガバナンス（AI RMF） — CISO・監査・規制対応向け

NIST AI RMF 1.0 の 4 機能（GOVERN/MAP/MEASURE/MANAGE）×17 サブカテゴリの充足状況进行评估する。クロスワーク表を通じて「ZTMM 実装が NIST のどの要件に対応するか」を経営層・監査担当に示す根拠資料となる。

3. 課題認識：なぜクロスマッピングが必要か

3.1 従来のアプローチの限界

- MITRE ATT&CK: 攻撃手法のカatalogだが「どう対処するか」の実装指針は提供しない。
- ZTMM: 成熟度モデルだが「レベルを上げるとどの脅威が消えるか」が不明確。
- NIST AI RMF: ガバナンス要件と技術的対策の接続が弱い。
- ATLAS: AI 特有の攻撃手法だが、従来セキュリティとの統合モデルがない。

核心的な価値提案

「ZTMM のこのコントロールを Lv1 から Lv3 に上げると、MITRE ATT&CK の T1078 と T1556 が緩和され、同時に NIST AI RMF の GV-1.1 要件の充足に寄与する」 — このような三軸横断の因果関係を、本ツールは自動的に導出する。

4. フレームワーク間の関係性（概念モデル）

4.1 ZTMM — ゼロトラスト実装の骨格

CISA ZTMM v2 は 6 ピラー×3 コントロール（合計 18）で構成され、各コントロールに Lv1（従来型）～Lv4（最適化/AI 統合）の 4 段階の成熟度がある。

ピラー	ID	コントロール名	概要
Identity	ID-O1	Authentication（認証）	MFA・パスワードレス・フィッシング耐性
	ID-O2	Identity Stores / NHI 対応	非人間 ID（AI エージェント等）の管理
	ID-O3	Risk Assessment	ID 関連リスクの継続的評価
Devices	DE-O1	資産管理 / AI BOM	AI モデル含む IT 資産の棚卸
	DE-O2	デバイス可視性	エンドポイントのリアルタイム監視
	DE-O3	コンプライアンス&ヘルス	デバイス準拠状態の管理
Networks	NW-O1	セグメンテーション	マイクロセグメンテーション実装
	NW-O2	トラフィック管理	トラフィックの可視化と制御
	NW-O3	暗号化・検査（PQC 対応検査）	TLS 検査・PQC 対応
App & Workload	AP-O1	アクセス戦略	アプリレベルのアクセス制御
	AP-O2	脅威防御（XAI）	AI 駆動の脅威検知と説明可能性
	AP-O3	アクセシビリティ	セキュアなアプリ公開
Data	DA-O1	棚卸・分類（BERT 文脈解析）	データの発見と分類
	DA-O2	アクセス制御	データレベルの認可
	DA-O3	暗号化（PQC 準拠）	データ暗号化（保存・転送・使用中・PQC 移行完了）
Cross-Cutting	CC-O1	可視性・分析（AISPM）	AI 資産含むセキュリティ態勢管理
	CC-O2	自動化	自動化・オーケストレーション・Human Verification Gate
	CC-O3	ガバナンス（EU AI Act）	PaC・規制対応・監査

4.2 脅威アクタープロファイル

v4.1.0 では 5 つの脅威アクターグループを内蔵し、各アクターが使用する技法でフィルタリン

グできる。

アクター	帰属	主要標的	特徴
APT29 / Cozy Bear	ロシア (SVR)	政府・外交・IT・製薬	サプライチェーン攻撃
APT28 / Fancy Bear	ロシア (GRU)	政府・軍・航空・政治	スパイフィッシング
Lazarus Group	北朝鮮 (RGB)	金融・暗号資産・防衛	ランサムウェア・金銭窃取
APT10 / MenuPass	中国 (MSS)	IT・MSP・製造 (日本重点)	Cloud Hopper 作戦
AI 悪用アクター (新興)	多様	AI 導入企業全般	プロンプトインジェクション等

5. クロスマッピングのメカニズム

5.1 コントロール依存関係

v4.1.0 では ZTMM コントロール間の依存関係を定義し、ロードマップ策定時に前提条件未達を警告する。

- 例: AP-O2（脅威防御）は AP-O1（アクセス戦略）と DE-O3（コンプライアンス）に依存
- 例: CC-O3（ガバナンス）は CC-O1（可視性）と CC-O2（自動化）に依存

6. ゼロトラスト実装のロードマップ

フェーズ	レベル遷移	期間目安	施策の性質	例
Quick Win	Lv1 → Lv2	即座～1 ヶ月	既存ツールの設定変更	MFA 有効化
Short-term	→ Lv3	3～6 ヶ月	新規ツール導入・統合	マイクロセグメンテーション
Strategic	→ Lv4	6～12 ヶ月	AI 統合・高度分析	AISPM 導入・Human Verification Gate

7. AI 時代のゼロトラスト拡張

7.1 主要な AI セキュリティ概念

NHI (Non-Human Identity) : AI エージェント、サービスアカウント等の非人間 ID。ID-O2 コントロールで管理。v4.1.0 では 6 カテゴリ（サービスアカウント/API キー/OAuth トークン/AI エージェント ID/証明書/CI CD パイプライン ID）に分類。

AI BOM: AI モデル・ライブラリのサプライチェーン管理。DE-O1 Lv4 で要求。

AISPM: AI 資産全体のセキュリティ態勢管理。CC-O1 Lv4 で実装。4 カテゴリ 16 指標のメトリクスを提供。

XAI (Explainable AI) : AI 判断の説明可能性。各脅威技法に XAI Level (1-5) を設定。

BERT Context Analysis: NLP を用いた A2A 通信/プロンプトの悪意検出。DA-O1 Lv4。

Human Verification Gate: AI エージェントの重要操作に対する人間承認ゲート。CC-O2 Lv4。

8. 本ツールの設計思想

観点	従来型（チェックリスト）	本ツール（実装駆動型）
起点	「何ができていないか」の確認	「どのレベルに上げるか」の設定
出力	ギャップ一覧（対策は別途）	アクションプラン自動生成
脅威との関連	手動紐付けまたは無し	自動計算（63 技法×18 コントロール）
ガバナンス	別プロセス	同時表示（クロスワーク表）
投資効果	定性的	定量的（N 件の脅威解消）
データ連携	なし	JSON import/export（Decision 連携）

9. v4.1.0 新機能一覧

機能	説明
ATLAS Phase 5（13 技法）	プロンプトインジェクション、RAG データ窃取、エージェン特セッションスマグリング等の AI 固有脅威 13 技法を統合
脅威アクタープロファイル	APT29/APT28/Lazarus/APT10/Generic AI Actor の 5 グループを内蔵、技法フィルタリング対応
業種別 TO-BE プリセット	金融・医療・製造・IT・政府・中小企業の 6 パターンで TO-BE レベルを一括適用
コントロール依存関係	18 コントロール間の前提条件を定義、ロードマップ策定時に依存関係を検証
サブテクニク展開	T1566、T1059、T1078 等の上位技法を下位手法に展開して詳細評価
JSON import/export	評価データの保存・復元、Decision とのデータ連携に対応
スナップショット比較	最大 5 件のスナップショットを保存し、AS-IS/TO-BE の時系列変化を比較
エグゼクティブレポート	ピラー別成熟度・Critical 優先アクション Top10・スナップショット履歴を 1 画面に集約
NHI 分類体系	6 カテゴリ（サービスアカウント/API キー/OAuth トークン/AI エージェント ID/証明書/CI CD）のリスクと対策を体系化
AISPM メトリクス	4 カテゴリ（インベントリ/リスク評価/セキュリティ監視/運用・ガバナンス）16 指標の管理ダッシュボード
ライト/ダークモード	プロジェクター投影（ライト）と通常作業（ダーク）の切替、WCAG AA コントラスト準拠
印刷対応	エグゼクティブレポートの印刷用 CSS 対応

10. 今後の展望

- Decision との統合深化: JSON 連携による ROI 自動計算との双方向データフロー確立
- Forg（組織摩擦診断ツール）との連携: 組織摩擦係数をアクション実現性の重み付けに反映
- MITRE ATT&CK / ATLAS の定期更新: 新規技法追加時のマッピング更新プロセスの標準化
- 多言語対応: 英語版レポート出力（CTO 訪問向け）の標準機能化

End of Concept Guide